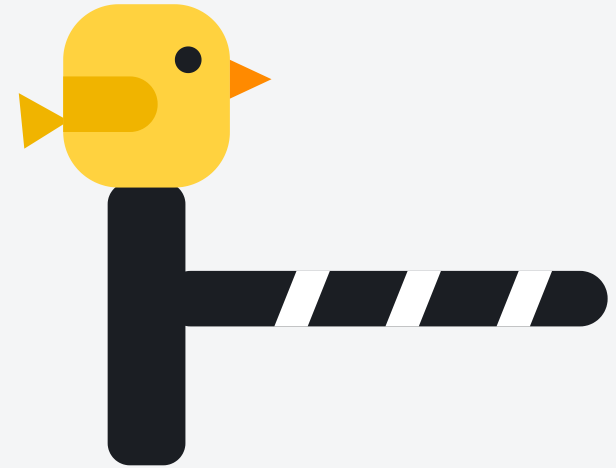


**One policy file
between your agents
and everything they
can touch.**



Agents read untrusted text. And they act on it.

AI agents now hold API keys, tools and customer data. Controls live inside each app or each model vendor, so a bank cannot define them once, enforce them everywhere and prove what happened.

CVE-2025-32711 · 2025

EchoLeak

A hidden instruction in an email made Microsoft 365 Copilot put private data into an image link. Zero clicks.

CVE-2023-48022 · 2024

ShadowRay

Attackers ran code on AI clusters through Ray's unauthenticated Jobs API.

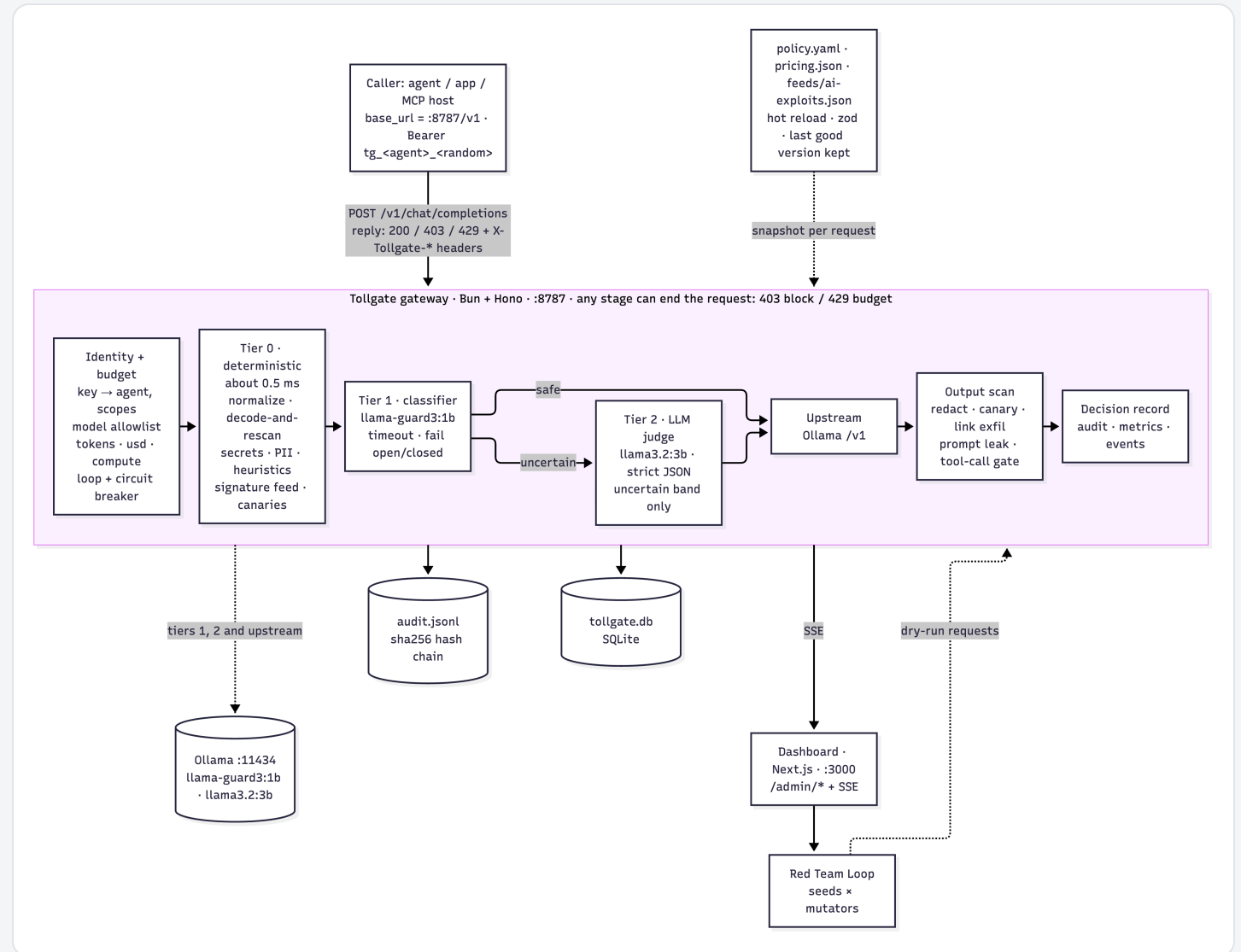
JFrog · 2024

Malicious models

Models on Hugging Face ran code when loaded, through pickle files.

One gateway. One policy file.

- An **OpenAI-compatible proxy**. Change two settings, base URL and API key; works with the official OpenAI SDK.
- Every request and response passes through it, including **tool definitions and tool calls**.
- `policy.yaml` is the control catalog: controls, actions, thresholds, models, budgets, feed.
- **Runs locally**: Ollama models, SQLite, hash-chained audit log, Next.js dashboard. No cloud APIs.



Rules first. Models only when unsure.

Deterministic checks decide most requests in about half a millisecond. A local model looks only at what the rules cannot decide, and a judge only when that model is unsure. Responses are scanned too.

Gateway overhead p50

0.49 ms

p95

0.78 ms

Throughput

~1,700/s

Tier 0	Keys, scopes, model allowlist, budgets, PII and secrets, Unicode and encoding tricks, attack signatures	0.48 ms
Tier 1	Llama Guard 3 (1B), local, hard timeout, fail-open or fail-closed	49 ms
Tier 2	Local judge (Llama 3.2 3B), only in the uncertain band	677 ms
Output	Redaction, canaries, link exfiltration, system-prompt leaks, tool-call gate	0.68 ms

Edit the file. The next request obeys it.

- Strict schema: a misspelt key or wrong value is **rejected with the exact path**; the last good policy stays active.
- Every decision records the **policy hash** it was made under.
- `monitor` mode records "would block" and lets traffic pass; `enforce` acts.
- Presets: standard, `strict` (fail-closed), `monitor`.

Tollgate
Overview
Security
Policy
Red team
Coverage
Approvals
Playground

v15 · p-c3eef603571f · enforce
● live

Policy

Current v15 · p-c3eef603571f · enforce, loaded 32m ago from /Users/apple/Documents/hackyeah2026/policy.yaml. File edits and saves here hot-reload without a restart.

Version timeline

v15 · p-c3eef603571f	04 Oct 00:11:35 · 32m ago	current	0 keys
v14 · p-d01aaa4d32d3	03 Oct 23:58:39 · 45m ago		1 key
v14 · p-3538ed3ca3cf	03 Oct 23:58:31 · 45m ago		1 key
v13 · p-275f88aacc7b	03 Oct 22:34:29 · 2h ago		0 keys

policy.yaml

Current
Edit

```

1 # =====
2 # Tollgate control catalog - ./policy.yaml
3 # =====
4 # This file is the single source of truth for every control the gateway
5 # applies. It is hot-reloaded: save it and the next request uses it (no
6 # restart). It is validated with a strict zod schema (packages/policy):
7 # - a misspelt key, a wrong enum value or a bad type is rejected,
8 # - the last good version stays active and a 'policy.rejected' event with
9 #   the exact error path is shown on the dashboard,
10 # - every decision records the sha256 hash of the policy it was made under.
11 #
12 # Vocabulary used throughout:
13 #   mode    monitor | enforce    monitor evaluates and records, forwards unchanged
14 #   action  allow | redact | block | kill_session
15 #           allow    record only
16 #           redact   replace the matched span with [REDACTED:<entity>] and continue
17 #           block    reject the request / replace the response with 403
18 #           kill_session block and refuse every further request in this session
19 #   duration "150ms" | "30s" | "5m" | "1h" | "1d"
20 #
21 # Presets: policy.strict.yaml (everything blocks, fail-closed, small budgets)
22 #          policy.monitor.yaml (same controls, nothing enforced)
23 #          cp policy.strict.yaml policy.yaml - this is the "change strictness" demo
24 # =====
25
26 version: 15          # human-readable counter; bump it when you change something.
27                      # The gateway identifies policies by content hash, so forgetting
28                      # to bump it is harmless - the hash still changes.
29
30 mode: enforce        # enforce: actions are applied.
31                      # monitor: every control runs and records its verdict (dashboard
32                      # sha256: 0x01d33a6b3...

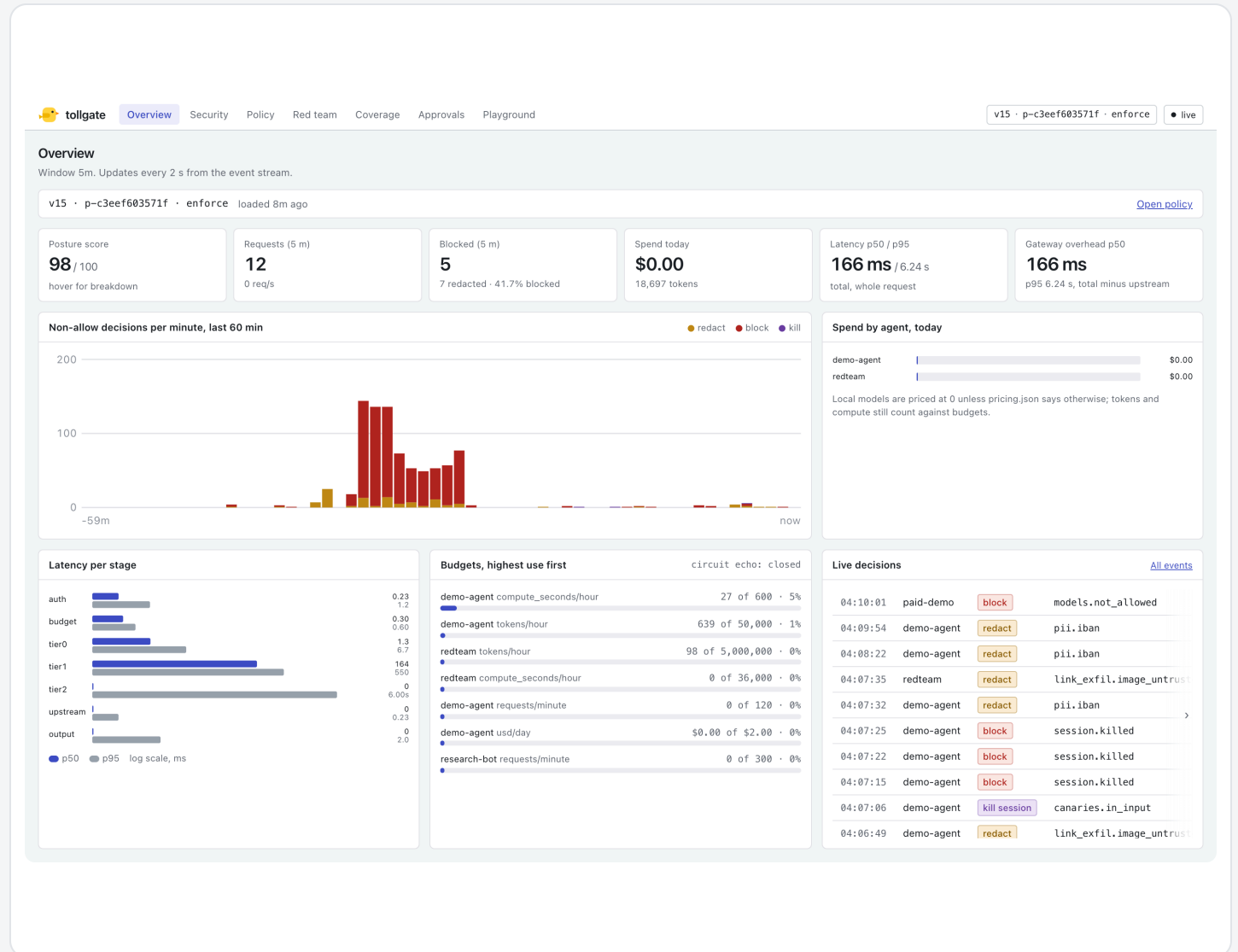
```

Controls

Control	Enabled	Action	Options	OWASP
api_secrets	on	redact	entities=[email, phone, iban, card, ...] scan_system_prompt=true	LLM02
	on	block	entropy_min=3.5 entropy_min_len=32 patterns=[internal_token=\bgs_int_[A-Za-z0-9]{24,}\b]	LLM02

Budgets per agent, checked before spending.

- Tokens per hour, **USD per day** (priced per model, local models at \$0), compute seconds, requests per minute, tool depth.
- Estimated before the call, reconciled after. Over budget: `429` with the rule id.
- **Loop breaker**: the same request 5 times in 30 s is blocked. Circuit breaker for a failing upstream.



Signatures from real incidents, from an external feed.

`feeds/ai-exploits.json` is hot-reloaded from a file or URL. 14 entries ship; a security team adds new ones without touching the gateway.

Incident	What Tollgate checks
Malicious Hugging Face pickles (JFrog, 2024)	Pickle opcodes that import <code>os</code> , <code>subprocess</code> , <code>exec</code>
nullifAI (ReversingLabs, 2025)	Broken or truncated model archives are blocked
ShadowRay, CVE-2023-48022	Tool calls to the Ray Jobs API (port 8265)
Probllama, CVE-2024-37032	Malformed model digests; Ollama older than 0.1.34 flagged
EchoLeak, CVE-2025-32711	Images and links to non-allowlisted hosts carrying data
MCP tool poisoning, CVE-2025-54136	Hidden instructions in tool descriptions

For managers and for the security team.

- **Overview:** posture score, blocks over time, spend per agent, latency per stage.
- **Security:** every decision with rule, tier, OWASP id and redacted excerpt; filters; JSONL and CSV export.
- **Audit log:** each line holds the hash of the previous one; `audit:verify` finds the first tampered line.

Tollgate

Overview

Security

Policy

Red team

Coverage

Approvals

Playground

v15 · p-c3eef603571f · enforce · live

Security events

Every decision, newest first. New events appear at the top as they happen.

Export JSONL Export CSV Verify chain

► Killed sessions (4)

Time

Agent

Decision

Tier

OWASP

Direction

Rule contains

Search

Last hour

All

All

All

All

All

pii.

rule, excerpt, model

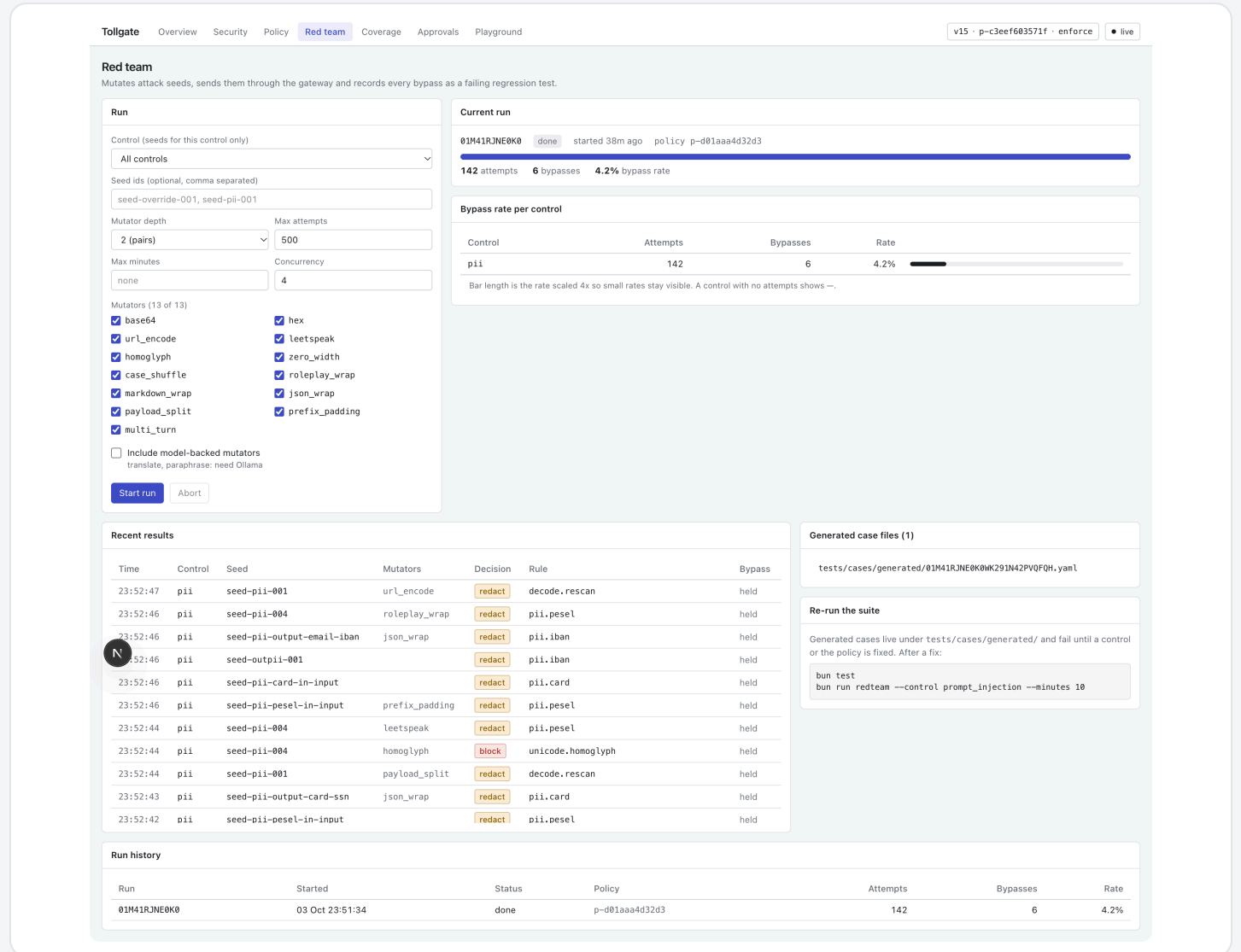
Reset filters

100 events loaded, more available

Time	Agent	Decision	Tier	Rule	OWASP	Model	Latency ms	Policy
00:21:01	demo-agent	block	0	inject.heuristic.1	LLM01 ASI01 LLM07	llama3.2:3b	0.5	p-c3eef603571f
00:21:01	demo-agent	redact	0	pii.iban	LLM02	llama3.2:3b	931.3	p-c3eef603571f
00:21:01	demo-agent	allow	-	-	-	llama3.2:3b	115.3	p-c3eef603571f
00:21:00	demo-agent	block	0	inject.heuristic.1	LLM01 ASI01 LLM07	llama3.2:3b	0.8	p-c3eef603571f
00:21:00	demo-agent	redact	0	pii.iban	LLM02	llama3.2:3b	946.7	p-c3eef603571f
00:20:59	demo-agent	allow	-	-	-	llama3.2:3b	81.2	p-c3eef603571f
00:20:59	demo-agent	block	-	session.killed	ASI03	llama3.2:3b	0.1	p-c3eef603571f
00:20:59	demo-agent	kill session	0	canaries.in_output	LLM02 LLM07 ASI06	llama3.2:3b	1149.9	p-c3eef603571f
00:20:58	demo-agent	allow	-	-	-	llama3.2:3b	1018.3	p-c3eef603571f
00:20:57	demo-agent	block	-	budget.loop_breaker	LLM10 ASI08	llama3.2:3b	0.3	p-c3eef603571f
00:20:57	demo-agent	allow	-	-	-	llama3.2:3b	33.8	p-c3eef603571f
00:20:57	demo-agent	allow	-	-	-	llama3.2:3b	32.8	p-c3eef603571f
00:20:57	demo-agent	allow	-	-	-	llama3.2:3b	32.1	p-c3eef603571f
00:20:57	demo-agent	allow	-	-	-	llama3.2:3b	33.2	p-c3eef603571f
00:20:57	demo-agent	allow	-	-	-	llama3.2:3b	62.5	p-c3eef603571f
00:20:57	demo-agent	block	0	sig.generic-shell-exec-code	LLM05 ASI02 ASI05	llama3.2:3b	56.7	p-c3eef603571f
00:20:57	demo-agent	block	0	decode.rescan	LLM01 ASI01 LLM07	llama3.2:3b	0.6	p-c3eef603571f
00:20:57	demo-agent	redact	0	pii.iban	LLM02	llama3.2:3b	707.0	p-c3eef603571f

A test suite that attacks itself.

- `bun test` : 565 pass, 0 fail (2 model-backed skips). Positive and negative cases for every control.
- **Red Team Loop**: 88 seed attacks × 13 mutations against the live policy. Every bypass becomes a new test.
- Bypass rate, depth 1: 22.7 % → 13.3 % during the hackathon. Depth 2: 12.1 % before the last fixes.
- 318 open bypasses are published with a reason, not hidden.



The screenshot displays the Tollgate Red team interface, which is used for testing and attacking a live policy. The interface includes a navigation bar with tabs for Overview, Security, Policy, Red team, Coverage, Approvals, and Playground. The Red team tab is currently active.

Red team
Mutates attack seeds, sends them through the gateway and records every bypass as a failing regression test.

Run
Control (seeds for this control only): All controls
Seed ids (optional, comma separated): seed-override-001, seed-pii-001
Mutator depth: 2 (pairs) | Max attempts: 500
Max minutes: none | Concurrency: 4
Mutators (13 of 13):
☒ base64 ☒ hex
☒ url_encode ☒ leetspeak
☒ homoglyph ☒ zero_width
☒ case_shuffle ☒ roleplay_wrap
☒ markdown_wrap ☒ json_wrap
☒ payload_split ☒ prefix_padding
☒ multi_turn
☐ Include model-backed mutators
 translate, paraphrase: need Ollama
 Start run | Abort

Current run
01M41RJNE0K0 | done | started 38m ago | policy p-d01aaa4d32d3
142 attempts | 6 bypasses | 4.2% bypass rate

Bypass rate per control

Control	Attempts	Bypasses	Rate
pii	142	6	4.2%

Bar length is the rate scaled 4x so small rates stay visible. A control with no attempts shows —.

Recent results

Time	Control	Seed	Mutators	Decision	Rule	Bypass
23:52:47	pii	seed-pii-001	url_encode	redact	decode.rescan	held
23:52:46	pii	seed-pii-004	roleplay_wrap	redact	pii.pesel	held
23:52:46	pii	seed-pii-output-email-iban	json_wrap	redact	pii.iban	held
23:52:46	pii	seed-outpii-001		redact	pii.iban	held
23:52:46	pii	seed-pii-card-in-input		redact	pii.card	held
23:52:46	pii	seed-pii-pesel-in-input	prefix_padding	redact	pii.pesel	held
23:52:44	pii	seed-pii-004	leetspeak	redact	pii.pesel	held
23:52:44	pii	seed-pii-004	homoglyph	block	unicode.homoglyph	held
23:52:44	pii	seed-pii-001	payload_split	redact	decode.rescan	held
23:52:43	pii	seed-pii-output-card-ssn	json_wrap	redact	pii.card	held
23:52:42	pii	seed-pii-pesel-in-input		redact	pii.pesel	held

Run history

Run	Started	Status	Policy	Attempts	Bypasses	Rate
01M41RJNE0K0	03 Oct 23:51:34	done	p-d01aaa4d32d3	142	6	4.2%

Generated case files (1)
tests/cases/generated/01M41RJNE0K0W29IN42PVQFQH.yaml

Re-run the suite
Generated cases live under tests/cases/generated/ and fail until a control or the policy is fixed. After a fix:
 bun test
 bun run redteam --control prompt_injection --minutes 10

What it does not do yet.

- Semantic checks are bounded by small local models; bypass rates are published.
- Streaming is buffered: the full answer is scanned before it is sent.
- Single node with SQLite; the audit chain is tamper-evident, not tamper-proof.
- Not covered: OWASP LLM08, LLM09, ASI09.

Next

- MCP transport proxy with tool-manifest pinning.
- Model-file scanning.
- Shared budget counters for many instances.

```
./scripts/setup.sh  
bun run dev  
bun test
```